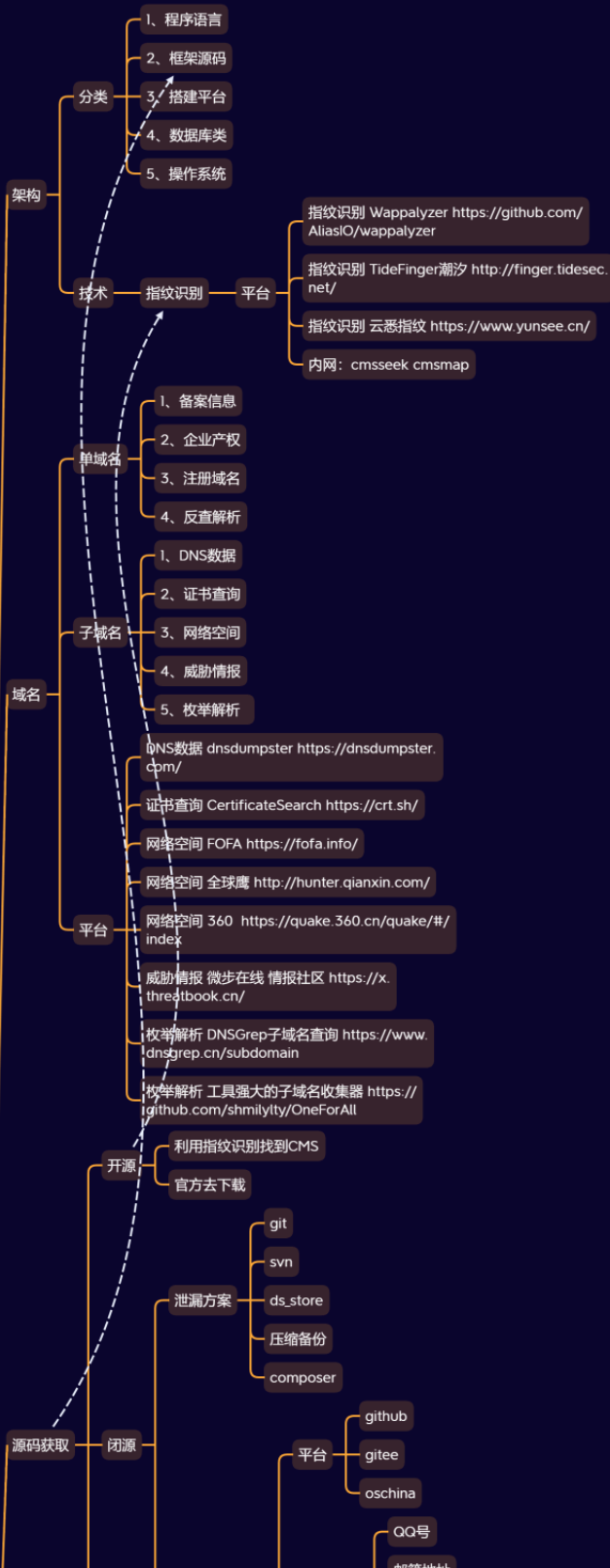


Day17 信息打点-语言框架&开发组件 &FastJson&Shiro&Log4j&SpringBoot等

业务资产

- 查询平台
 - 爱企查
 - 小蓝本
- 业务类型
 - 1、WEB应用
 - 2、APP应用
 - 3、PC端应用
 - 4、小程序应用
 - 5、微信公众号
 - 6、其他产品等



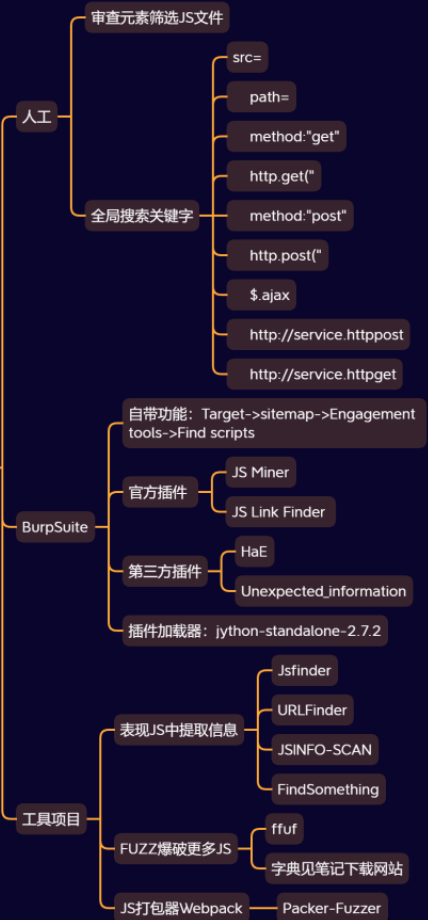
信息打点-小迪安全

① Web应用

JS前端架构

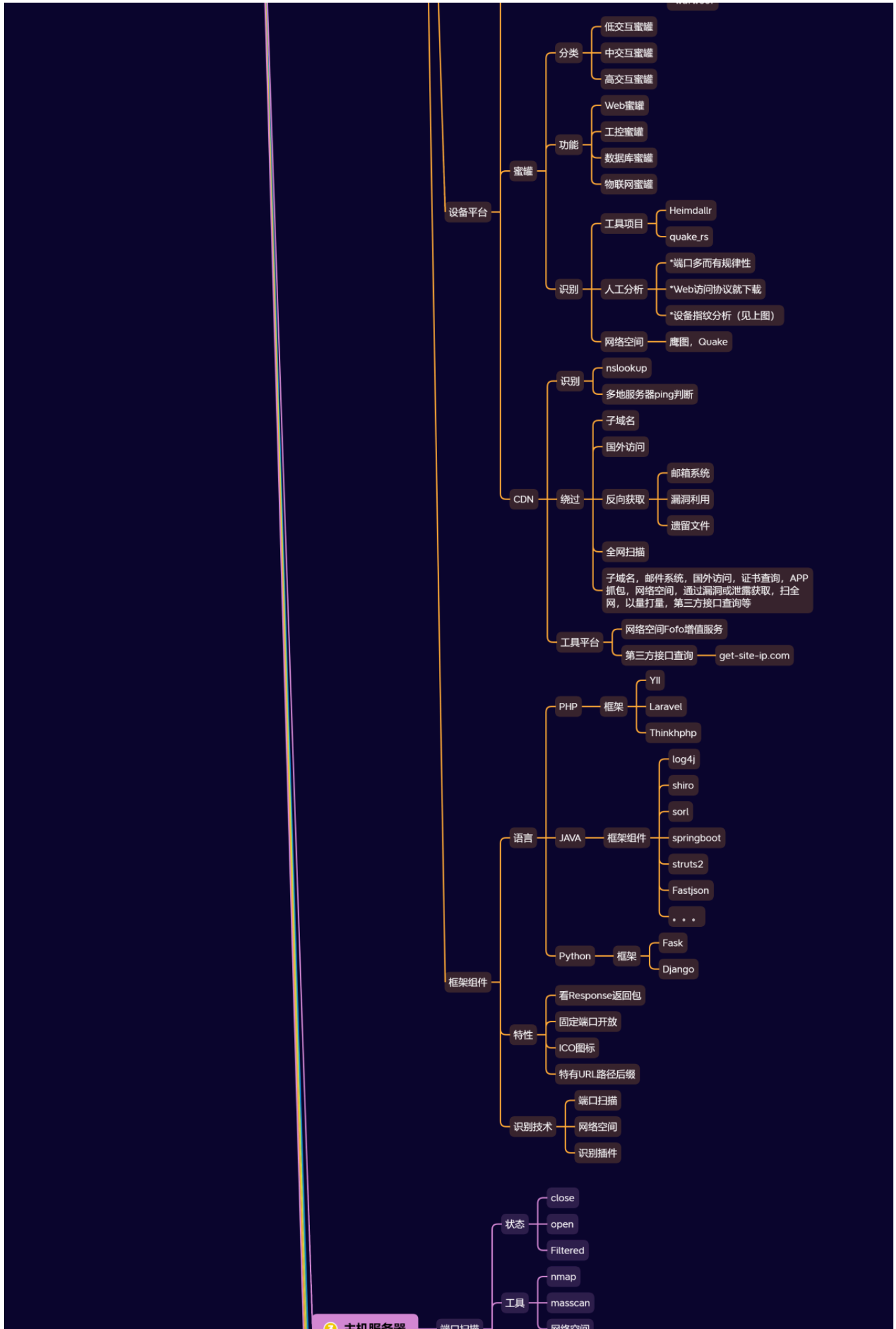


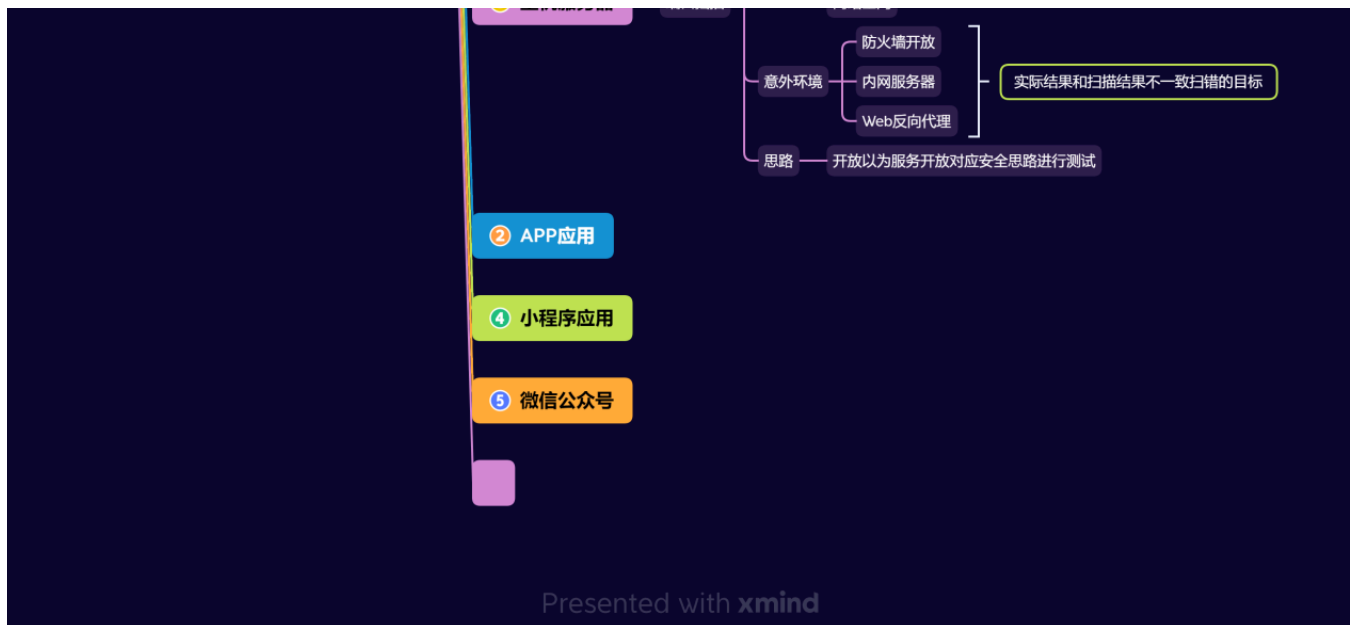
测试方法



WAF







1. 知识点

- 1、业务资产-应用类型分类
- 2、Web单域名获取-接口查询
- 3、Web子域名获取-解析枚举
- 4、Web架构资产-平台指纹识别

-
- 1、开源-CMS指纹识别源码获取方式
 - 2、闭源-习惯&配置&特性等获取方式
 - 3、闭源-托管资产平台资源搜索监控

-
- 1、JS前端架构-识别&分析
 - 2、JS前端架构-开发框架分析
 - 3、JS前端架构-打包器分析
 - 4、JS前端架构-提取&FUZZ

解决:

- 1、如何从表现中的JS提取价值信息
- 2、如何从地址中FUZZ提取未知的JS文件
- 3、如何从JS开放框架Webpack进行测试

-
- 1、端口扫描-应用&协议
 - 2、WAF识别-分类&识别
 - 3、蜜罐识别-分类&识别

解决:

- 1、Web服务器&应用服务器差异性
- 2、WAF防火墙&安全防护&识别技术
- 3、蜜罐平台&安全防护&识别技术

-
- 1、CDN 服务-解释差异识别
 - 2、CDN 绕过-配置差异导致
 - 3、CDN 绕过-主动连接获取
 - 4、CDN 绕过-全网扫描获取

解决:

- 1、CDN 服务对安全影响
- 2、CDN 服务绕过识别手法

-
- 1、CMS指纹识别-不出网程序识别
 - 2、开发框架识别-PHP&Python&Java
 - 3、开发组件识别-Java常见安全漏洞组件

解决:

- 1、CMS识别到后期漏洞利用和代码审计
- 2、开发框架识别到后期漏洞利用和代码审计
- 3、开发组件识别到后期漏洞利用和代码审计

2.详细点



- 1 CMS
- 2 Discuz、WordPress、Ecshop、蝉知等



- 1 前端技术
- 2 HTML5、jquery、bootstrap、Vue等



- 1 开发语言
- 2 PHP、JAVA、Ruby、Python、C#、JS等



- 1 web服务器
- 2 Apache、Nginx、IIS、lighttpd、Apache等



- 1 应用服务器:
- 2 Tomcat、Jboss、Weblogic、Websphere等



- 1 数据库类型:
- 2 Mysql、SqlServer、Oracle、Redis、MongoDB等



- 1 操作系统信息
- 2 Linux、windows等



- 1 应用服务信息:
- 2 FTP、SSH、RDP、SMB、SMTP、LDAP、Rsync等



- 1 CDN信息
- 2 帝联、Cloudflare、网宿、七牛云、阿里云等



- 1 WAF信息
- 2 创宇盾、宝塔、ModSecurity、玄武盾、OpenRASP等。



- 1 蜜罐信息:
- 2 HFish、TeaPot、T-Pot、Glastopf等



- 1 其他组件信息
 - 2 fastjson、shiro、log4j、OA办公等
-

3.演示案例

- 
- 1 后端:
 - 2 **CMS**: 一般PHP开发居多源码程序
 - 3 (利用源码程序名去搜漏洞情况, 源码去下载进行后期的代码审计)
 - 4
 - 5 前端:
 - 6 **js** 框架 (爬取更多的**js**从里面筛选**URL**或敏感泄漏**key**等)
 - 7 也是可以通过对**js**代码逻辑进行代码审计
 - 8
 - 9 组件: **java**居多,
 - 10 常见有过安全漏洞组件 (**shiro solr log4j sprintboot**等)
 - 11
 - 12 框架: **php java python**都有

- 
- 1 框架: 简单代码的一个整合库, 如果使用框架就只需要学习使用框架调用即可
 - 2 如: 文件上传功能是需要很多代码来实现的, 框架把这个代码进行封装, 调用即可
 - 3 影响: 如果采用框架开发, 代码的安全性是取决于框架的过滤机制
 - 4
 - 5 组件: 第三方的功能模块 (日志记录, 数据监控, 数据转换等)
 - 6
 - 7 **web架构**:
 - 8 1、最简单最入门的开发模型 (功能代码全部手写)
 - 9 最容易出现漏洞, 程序员水平不一, 没有第三方或团队的检测, 单纯的自己写
 - 10
 - 11 2、结合开发框架的开发模型 (以框架为核心实现功能)
 - 12 第三方或团队的开发的封装代码框架, 一般内置的过滤机制 (框架漏洞)
 - 13
 - 14 3、结合开发框架外加组件模型 (以框架为核心, 组件为辅实现功能)
 - 15 第三方或团队的开发的封装代码框架, 一般内置的过滤机制 (框架和组件漏洞)

3.1 指纹识别-本地工具-GotoScan

- 
- 1 指纹识别-本地工具-GotoScan (CMSEEK)
 - 2 1、在线平台见前面课程, 本地工具适用于不出网环境
 - 3 <https://github.com/newbe3three/gotoscan>
 - 4 2、网络空间: Fofa Quake Hunter
 - 5 3、网络空间: IO图标关系

3.2 Python-开发框架-Django&Flask



- 1 Django
- 2 1、识别插件
- 3 2、Set-Cookie:expires=
- 4
- 5 Flask
- 6 1、识别插件
- 7 2、Set-Cookie:expires=

3.3 PHP-开发框架-ThinkPHP&Laravel&Yii



- 1 ThinkPHP:
- 2 0、识别插件
- 3 1、X-Powered-By: ThinkPHP
- 4 2、CMS识别到源码体系TP开发
- 5
- 6 Laravel:
- 7 1、识别插件
- 8 2、Set-Cookie中特征的格式
- 9
- 10 Yii:
- 11 1、识别插件
- 12 2、Set-Cookie中特征的格式

3.4 Java-框架组件-FastJson&Shiro&Solr&Spring



- 1 52类110个主流Java组件和框架介绍:
- 2 <https://blog.csdn.net/agonie201218/article/details/125300729>.
- 3
- 4 Fastjson/Jackson
- 5 在提交JSON数据包中修改测试:
- 6 -Fastjson组件会把01解析成1
- 7 -Jackson组件在解析01时会抛出异常
- 8 <https://forum.butian.net/share/1679>
- 9 <https://www.iculture.cc/forum-post/24115.html>
- 10
- 11 Shiro
- 12 请求包的cookie中存在rememberMe字段。
- 13 返回包中存在set-Cookie: remeberMe=deleteMe。
- 14 请求包中存在rememberMe=x时，响应包中存在rememberMe=deleteMe。
- 15 有时候服务器不会主动返回remeberMe=deleteMe，直接发包即可，将Cookie内容改为remember Me=1，若相应包有rememberMe=deleteMe，则基本可以确定网站apache shiro搭建的。
- 16
- 17 Struts2

18 一般使用struts2框架后缀带do或action, 可以尝试进行利用

19

20 Springboot

21 1、通过web应用程序网页标签的小绿叶图标

22 2、通过springboot框架默认报错页面

23

24 so1r识别

25 一般开放8983端口, 访问页面也可以探针到